ANKASEC SİBER GÜVENLİK MÜHENDİSLİĞİ EĞİTİMİ - 2026

101 BİTİRME PROJESİ: "The Analyst & The Hunter"

11 MART 2026

METEHAN EROĞLU

Bölüm A: Teori ve Mimari (Research & Logic)

1. **İşletim Sistemi ve Şifreleme: "Anahtarlar Kimde?"**

- SSH Private Key (Gizli Anahtar): Parola (Password) ile giriş yapmak varken, sunuculara bağlanırken neden SSH Anahtarları (Public/Private Key) kullanırız? Bu sistemin güvenliğini sağlayan temel mantık nedir?

Parola yerine SSH Anahtarlarını kullanmamızın birkaç farklı sebebi var bunlar:

1. Brute-Force kullanarak SSH anahtarını çözemeyiz çözmek istesek bile asırlar alır,
2. Girilen private key asla kendi cihazımızdan dışarı çıkmaz.

SSH Anahtarının çalışma mantığı şudur:

1. Sunucu sana public key ile şifrelenmiş rastgele bir veri dosyası yollar.
2. Bizde bu dosyayı private key ile çözerek sunucuya geri yollarız. Eğer içindeki şifrelenmiş dosyayı doğru bir şekilde okumuşsak bizi içeri alır.

- **Hex Dump:** Bilgisayarlar için yazılmış binary (ikili) dosyaları okunabilir hale getiren "Hex Dump" nedir?
  - Hex dump bizim anlayamadığımız 0 ve 1 leri anlayabileceğimiz bir formata dönüştürür.

2. **Web Mimarisi: "Sunucu Tarafı (Server-Side)"**

- Client-Side vs Server-Side: Bir web sayfasında "Sağ tık > Kaynağı İncele" dediğimizde HTML ve JavaScript kodlarını (Client-side) görebilirken, neden PHP veya Python (Server-side) kodlarını göremeyiz?

Bir web sitesinin kaynağını incelediğimizde sadece HTML ve JavaScript dosyalarını görürüz çünkü:

1. JavaScript ve HTML bizim bilgisayarımızda çalışan kodlardır. Bu yüzden bu alandaki güvenlik zafiyetleri genellikle **XSS** gibi saldırılara yol açar. (Client-Side)

2. Python ve PHP kodlarını görememizin sebebi ise bu kodların sunucu tarafından cevaplanıp sonuçlarının bize gönderilmesidir. Bu alandaki saldırılarda genellikle **SQL injection** saldırıları olur. (Server-Side)

- Command Injection (Komut Enjeksiyonu): Bir web sitesindeki arama kutusuna yazılan masum bir metin, nasıl olur da arka plandaki Linux sunucusunda ls veya whoami komutlarının çalışmasına neden olur?

  - Bu olaya command injection denir bunun olmasının sebebi ise yazdığımız sorgunun bir linux terminalinde çalıştırılmasıdır. Mesela ben domain bulan bir web sitesinin arama satırına Google.com | whoami , Google.com && whoami veya Google.com ; whoami yazdığımı varsayalım ve arkaplanda Linux kullansın önce Google.com un domainlerini bulur ondan sonrada operatörler sayesinde (| && ;) whoami komutunu çalıştırır.

3. Ağ Anatomisi: "Avın İzleri"

- C2 (Command an C2 (Command and Control) Nedir? Bir bilgisayara zararlı yazılım (Malware) bulaştığında, bu yazılım neden hacker'ın "C2 Sunucusuna" bağlanma ihtiyacı duyar?

- Öncelikle C2 sunucusu nedir ondan bahsedelim C2(Comand and Control) uzaktan kontrol mekanizmasıdır. Zararlı yazılımın emir alabilmesi için buna bağlanması gerekir buna bağlandıktan sonra saldırgan yetkisine göre cihaz üzerinden işlemler yapabilir.

- PCAP Analizi: Bir SOC (Güvenlik Operasyon Merkezi) analisti, zararlı yazılımı tespit etmek için neden sadece antivirüs loglarına güvenmez de ağdaki PCAP (Packet Capture) dosyasını inceleme ihtiyacı duyar?

  - Çünkü antivirüs programları fotoğraf gibidir ben şurda şu virüsü buldum ve karantinaya aldım der ama pcap dosyaları video kaydıdır IP adresleri ,MAC adresleri ,port numrası vb. her şeyi gösterir.

Bölüm B: Saha Operasyonu (Boss Fights)

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

- **Hedef: OverTheWire: Bandit**
- **Görev: Level 11'den başlayıp Level 15'e kadar (15 dahil) tamamlayın.**
- **Beklenti & Raporlama: * Level 13'te SSH Private Key (.ssh/id_rsa) kullanarak diğer kullanıcıya nasıl geçtiniz?**
    - **Level 14'te nc (Netcat) ile localhost'taki bir porta veriyi nasıl gönderdiniz?**
    - **Kullanılan komutları ve terminal ekran görüntülerini ekleyin.**

11→12

- Bir sonraki seviyenin parolası, data.txt dosyasında saklanmıştır. Bu dosyada tüm küçük (a-z) ve büyük (A-Z) harfler 13 pozisyon döndürülmüştür.

1. Öncelikle cmd üzerinden ssh bandit11@bandit.labs.overthewire.org -p 2220 yazıp ssh ile bağlanıyoruz. Şifre=dtR173fZKb0RRsDFSGsg2RWnpNVj3qRr (10→11 çözdüğümüzde bulmuştuk.)
2. Burada bahsedilen olay ROT13 cipher. Yani her harf kendinden sonraki 13. harfe kaydırılmış.

```
bandit11@bandit:~$ cat data.txt
Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4
bandit11@bandit:~$ cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m'
The password is 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
bandit11@bandit:~$
```

3. cat data.txt | tr 'A-Za-z' 'N-ZA-Mn-za-m' komutunu kullanarak şifreyi ortaya çıkardık.(Bu kodda ki mantık 'A-Za-z' bütün büyük ve küçük harfleri seç a dan z ye ; 'N-ZA-Mn-za-m' n harfi z yi a harfi m yi temsil eder.)

12→13

- Bir sonraki seviyenin parolası, data.txt dosyasında saklıdır. Bu dosya, defalarca sıkıştırılmış bir dosyanın hexdump çıktısıdır. Bu seviyede çalışmak için /tmp altında bir dizin oluşturmanız faydalı olabilir. Tahmin edilmesi zor bir dizin adıyla mkdir kullanabilirsiniz. Daha iyisi, mktemp -d komutunu kullanmaktır. Daha sonra cp komutuyla veri dosyasını kopyalayın ve mv komutuyla yeniden adlandırın (man sayfalarını okuyun!).

1. Öncelikle cmd üzerinden ssh bandit12@bandit.labs.overthewire.org -p 2220 yazıp ssh ile bağlanıyoruz. Şifre= 7x16WNeHIi5YkIhWsfFIqoognUTyj9Q4
2. Bu soruda 3 tane sıkıştırma formatı var.(gzip, bzip2,tar). Öncelikle

```
bandit12@bandit:~$ mktemp -d
/tmp/tmp.M6b84YpLAn
bandit12@bandit:~$ cd /tmp/tmp.M6b84YpLAn
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ cp ~/data.txt .
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ xxd -r data.txt > data
```

3. Mktemp -d ile geçici bir yer oluşturuyoruz ,
4. cd /tmp/tmp.M6b84YpLAn buraya gidiyoruz(sizinkini ismi farklı olucak),
5. cp ~/data.txt . dosyamızı bu klasöre kopyalıyoruz,
6. Bundan sonraki her adımda önce file data diyerek türünü bakıyoruz eğer gzip çıkarsa:

```
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ mv data data.gz
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ gunzip data.gz
```

Bzip2 çıkarsa:

```
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ mv data data.bz2
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ bunzip2 data.bz2
```

Tar çıkarsa:

```
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ mv data data.tar
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ tar -xf data.tar
```

(tar dan sonra dosya ismi değişiyor data5.bin tarzı oluyor)

7. Bu şekilde ilerleyerek en son şifreye ulaşıyoruz(ASCII text)

```
bandit12@bandit:/tmp/tmp.M6b84YpLAn$ cat data
The password is FO5dwFsc0cbaIiH0h8J2eUks2vdTDwAn
```

13→14

- Bir sonraki seviyenin parolası /etc/bandit_pass/bandit14 dosyasında saklanmaktadır ve bu dosya yalnızca bandit14 kullanıcısı tarafından okunabilir. Bu seviyede size doğrudan bir sonraki parolayı vermiyoruz; bunun yerine bir özel SSH anahtarı veriyoruz. Bu anahtar, bir sonraki seviyeye giriş yapmak için kullanılabilir. Önceki bandit seviyelerine giriş yaparken kullandığınız komutlara bakın ve bu seviyede anahtarı nasıl kullanacağınızı bulun.

(Normalde bu soruyu iç içe ssh kullanarak çözmemiz gerekiyor ama anlamadığım bir hata yüzünde çözemiyorum o yüzden başka bir yoldan çözücem)

```
┌──(kali㉿kali)-[~]
└─$ scp -P 2220 bandit13@bandit.labs.overthewire.org:/home/bandit13/sshkey.private .
The authenticity of host '[bandit.labs.overthewire.org]:2220 ([51.21.210.216]:2220)' can't be established.
ED25519 key fingerprint is: SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[bandit.labs.overthewire.org]:2220' (ED25519) to the list of known hosts.
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                       This is an OverTheWire game server.
             More information on http://www.overthewire.org/wargames

backend: gibson-0
bandit13@bandit.labs.overthewire.org's password:
sshkey.private                                                100% 1679     7.1KB/s   00:00
```

1. Öncelikle ssh anahtarını kendi bilgisayarıma indiriyorum.

```
┌──(kali㉿kali)-[~]
└─$ chmod 600 sshkey.private
```

2. Yukardaki kodu yazarak izinlerini değiştiriyoruz sadece kişinin kendisi okuyup yazabilir.
3. ssh -i sshkey.private bandit14@bandit.labs.overthewire.org -p 2220 komutunu yazarak içeri giriyoruz.

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPaLh7lDCPvS
```

4. Ve bize soruda verildiği yere gidiyoruz.

14→15

- Bir sonraki seviyenin parolası, mevcut seviyenin parolasını **localhost** üzerindeki **30000** numaralı porta göndererek alınabilir.

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14 | nc localhost 30000
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
```

5. Bandit 14 ten çıkmadan önce şifreyi okuyup netcat aracı ile bağlandığımızda şifre ortaya çıkıyor.

15→16

- Bir sonraki seviyenin parolası, mevcut seviyenin parolasını **localhost** üzerindeki **30001** numaralı porta **SSL/TLS şifrelemesi** kullanarak göndererek alınabilir.

1. Öncelikle bandit 15 e bağlıyoruz.
2. Buradada aynı mantık ama ssl kullanıcaz

```
bandit15@bandit:~$ openssl s_client -connect localhost:30001
```

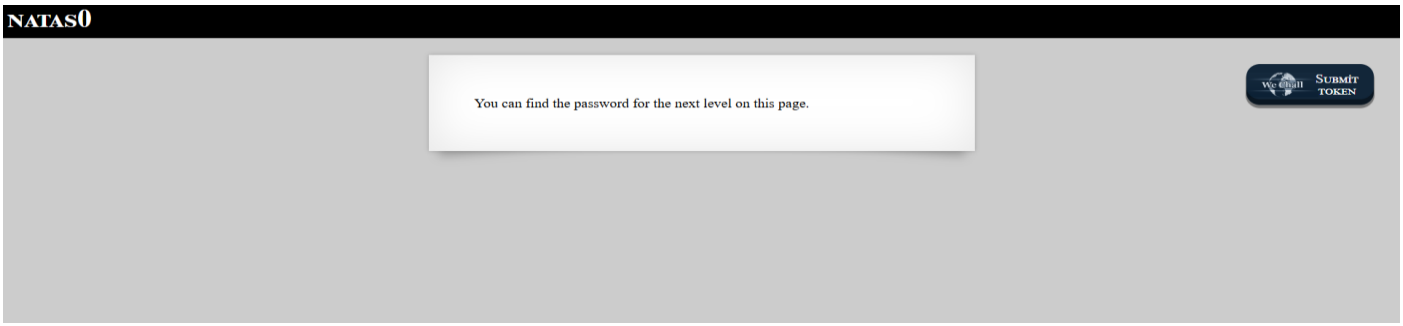
3. Komutunu kullanarak sunucuya bağlanıyoruz ve bandit 15 şifresini giriyoruz.

```
read R BLOCK
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
Correct!
kSkvUpMQ7lBYyCM4GBPvCvT1BfWRy0Dx
```

Cephe 2: Web Mantık Avcısı (Server-Side)

- **Hedef:** OverTheWire: Natas
- **Görev: Level 0'dan Level 10'a kadar** (10 dahil) kesinlikle çözülmelidir.
- **Beklenti & Raporlama:**
  - Bu laboratuvar Burp Suite gerektirir!
  - Seviyeleri geçerken bulduğunuz zafiyetin türünü belirtin. (Örn: "Burada gizli dizin (Directory Listing) buldum", "Burada Local File Inclusion (LFI) ile /etc/natas_webpass dosyasını okudum").
  - Kaynak kod analizlerinizi ve Burp Suite / Tarayıcı ekran görüntülerini raporlayın.

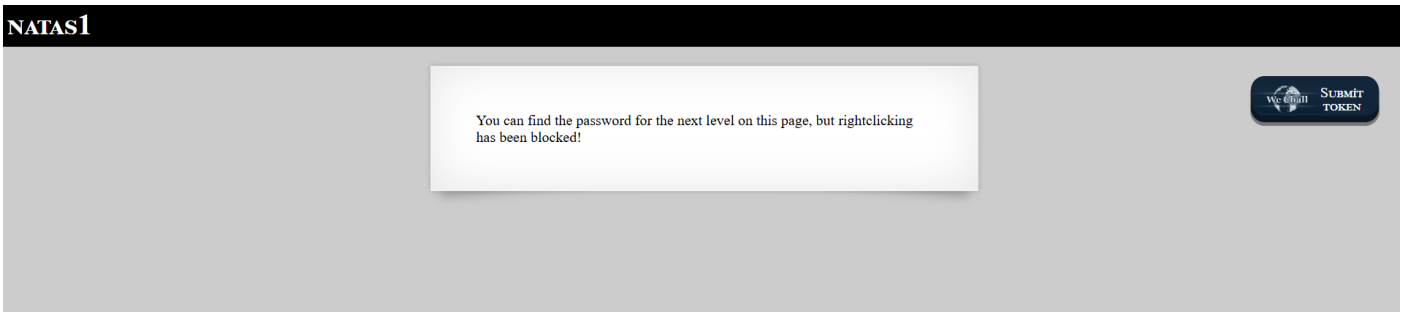
0



Bizi böyle bir sayfa karşılıyor bu sayfaya kaynak incelemesi yaparsak şifreyi buluruz.

```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas0", "pass": "natas0" };</script></head>
<body>
<h1>natas0</h1>
<div id="content">
You can find the password for the next level on this page.

<!--The password for natas1 is 0nzCigAq7t2iALyvU9xcHlYN4MlkIwlq -->
</div>
</body>
</html>
```

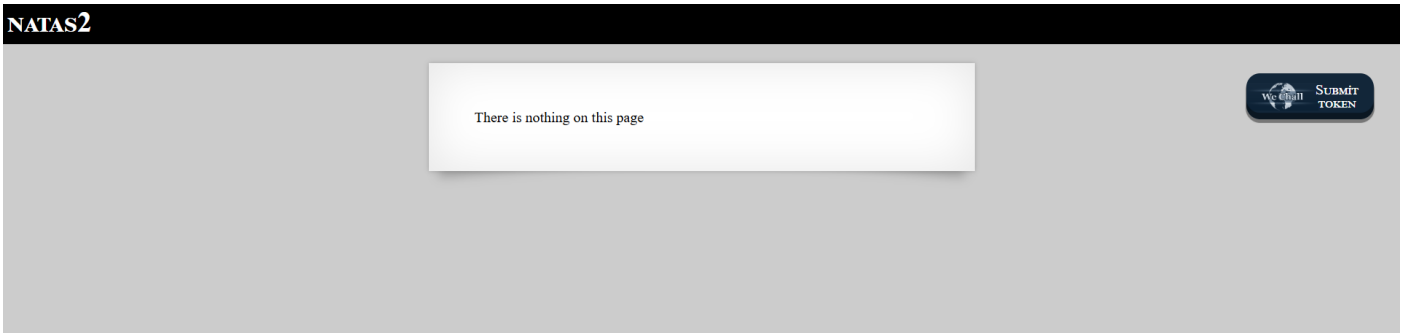
0→1



Sayfanın sağ tık bloklanmış bizde url nin başına view-source: yazarak kaynak koduna ulaşabiliriz.

```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas1", "pass": "0nzCigAq7t2iALyvU9xcHlYN4MlkIwlq" };</script></head>
<body oncontextmenu="javascript:alert('right clicking has been blocked!');return false;">
<h1>natas1</h1>
<div id="content">
You can find the password for the
next level on this page, but rightclicking has been blocked!

<!--The password for natas2 is TguMNxKo1DSa1tujBLuZJnDUlCcUAPlI -->
</div>
</body>
</html>
```

1→2



Karşımıza böyle bir sayfa çıkıyor bu sayfanın kaynağını inceliyoruz.

```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas2", "pass": "TguMNxKo1DSa1tujBLuZJnDUlCcUAPlI" };</script></head>
<body>
<h1>natas2</h1>
<div id="content">
There is nothing on this page
<img src="files/pixel.png">
</div>
</body></html>
```

Görüldüğü üzere files dizini altında bir dosya var. Bu dizin altında daha fazla dosya varmı diye url nin sonuna /files/ yazıyoruz.

Index of /files

Name	Last modified	Size	Description
Parent Directory		-	
pixel.png	2025-10-14 09:06	303	
users.txt	2025-10-14 09:06	145	

Apache/2.4.58 (Ubuntu) Server at natas2.natas.labs.overthewire.org Port 80

Buradaki user.txt içine giriyoruz.

```
# username:password
alice:BYNdCesZqW
bob:jw2ueICLvT
charlie:G5vCxkVV3m
natas3:3gqisGdR0pjm6tpkDKdIWO2hSvchLeYH
eve:zo4mJWyNj2
mallory:9urtcpzBmH
```

Natas3 ü bulmuş olduk

2→3

Burada Robots.txt kullanıcaz robots.txt bize tüm alt dizinleri gösterir.

Güvenli değil natas3.natas.labs.overthewire.org/robots.txt

```
User-agent: *
Disallow: /s3cr3t/
```

Ve burada /s3cr3t/ dizini olduğunu görüyoruz.

Güvenli değil natas3.natas.labs.overthewire.org/s3cr3t/

Index of /s3cr3t

Name	Last modified	Size	Description
Parent Directory		-	
users.txt	2025-10-14 09:06	40	

Apache/2.4.58 (Ubuntu) Server at natas3.natas.labs.overthewire.org Port 80

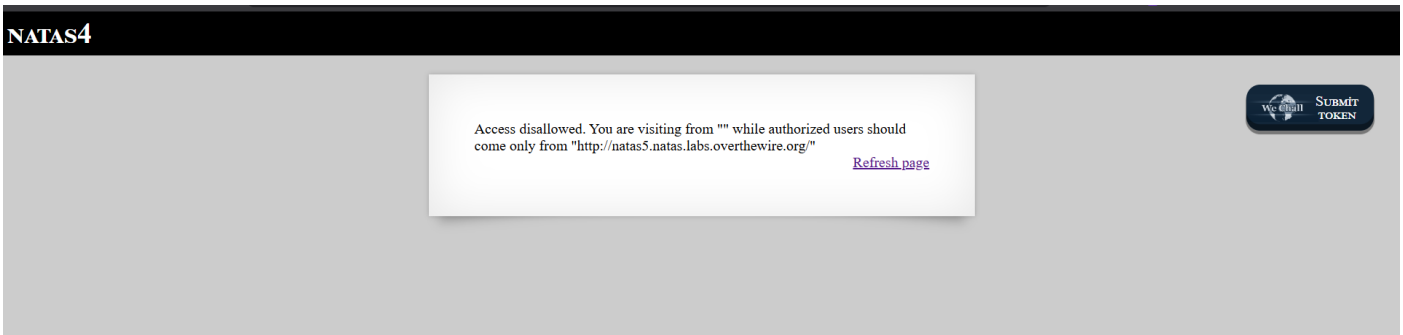
Burada da user.txt var.

İçine girdiğimizde şifre karşımıza çıkıyor.

Güvenli değil natas3.natas.labs.overthewire.org/s3cr3t/users.txt

```
natas4:QryZXc2e0zahULdHrtHxzyYkj59kUxLQ
```

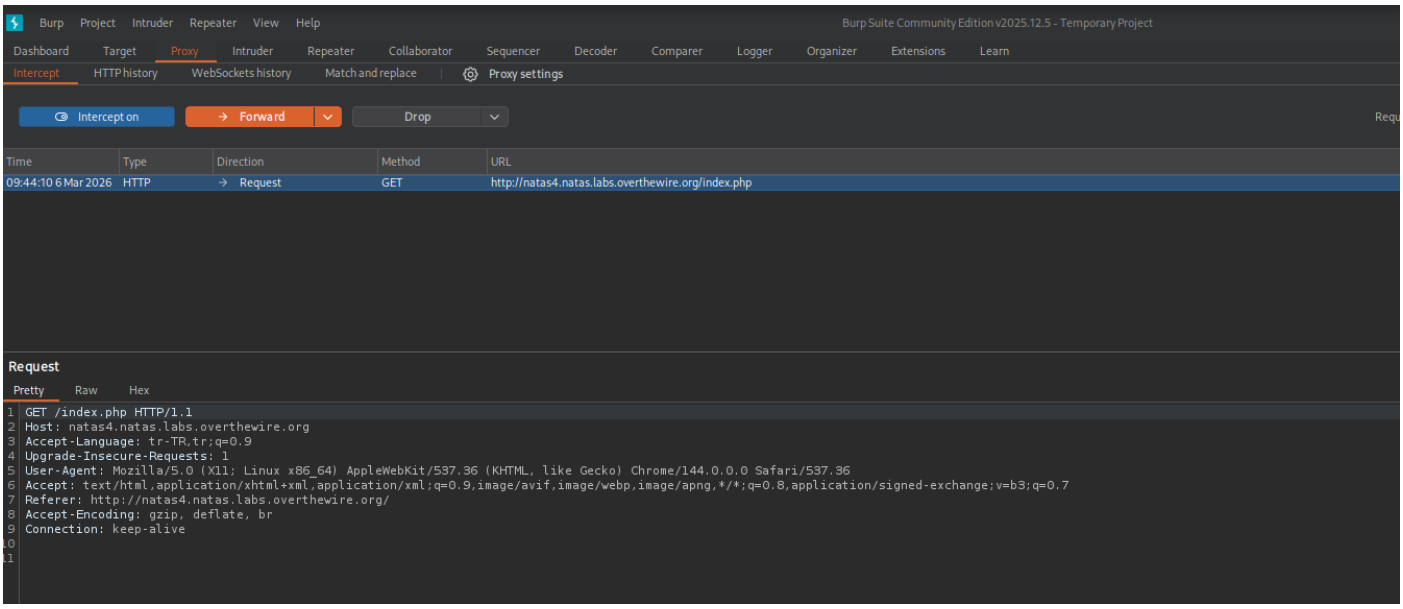
3→4



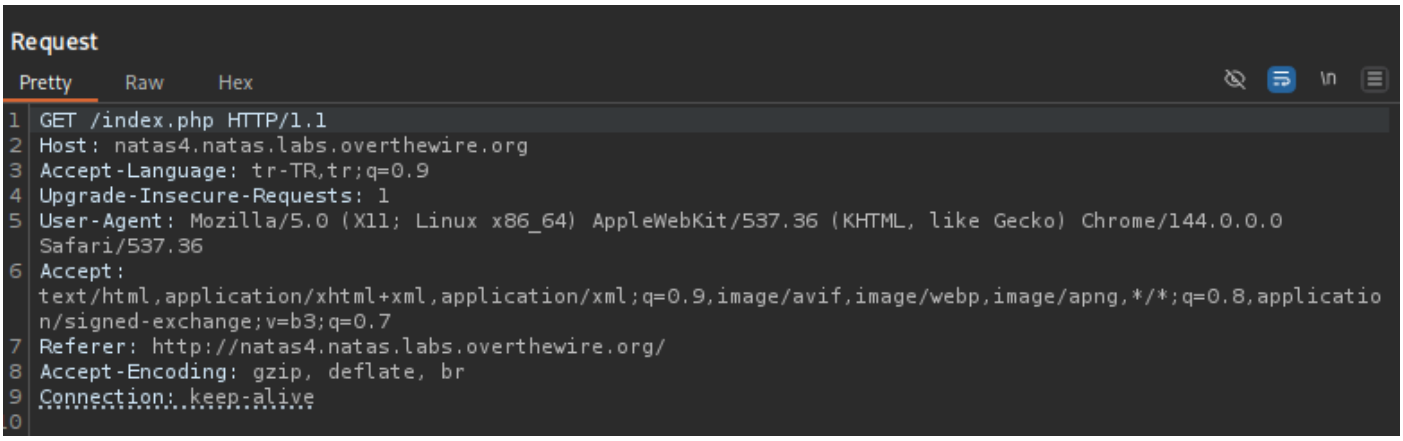
Burada yetkisiz olduğumuz gösteriliyor ve yetkili kişinin http://natas5.natas.labs.overthewire.org/ adresinden gelmesi gerektiğini söylüyor. Bu yüzden Burp Suit kullanmamız gerekiyor.

Burp suıt tarayıcısını açıyoruz ve siteye gidiyoruz.(Proxy kısmı)

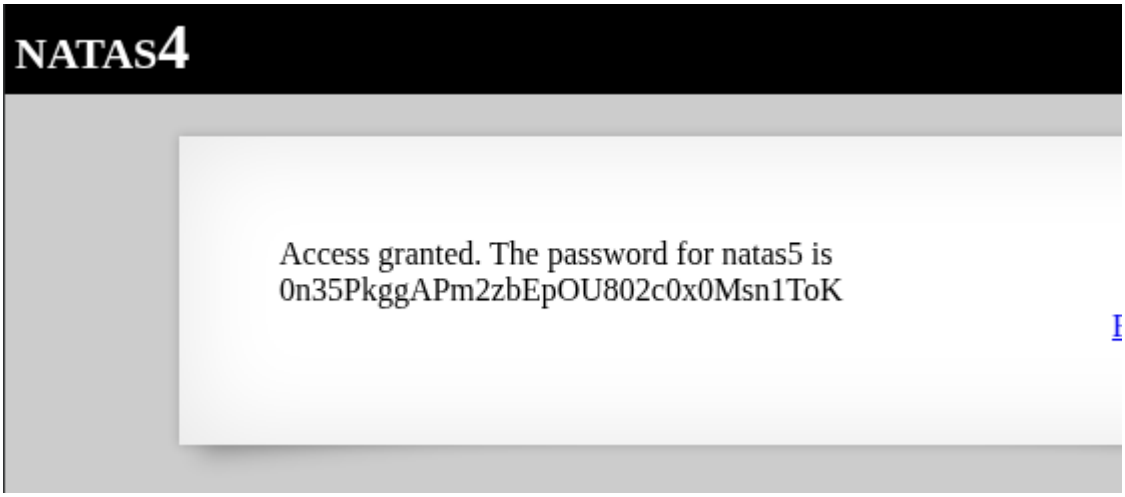
İntercept kısmını on yapıyoruz. Ve refresh page diyoruz bu sayede istek burp suıt e düşüyor.



Bu isteği repeater e göndeeriyoruz.

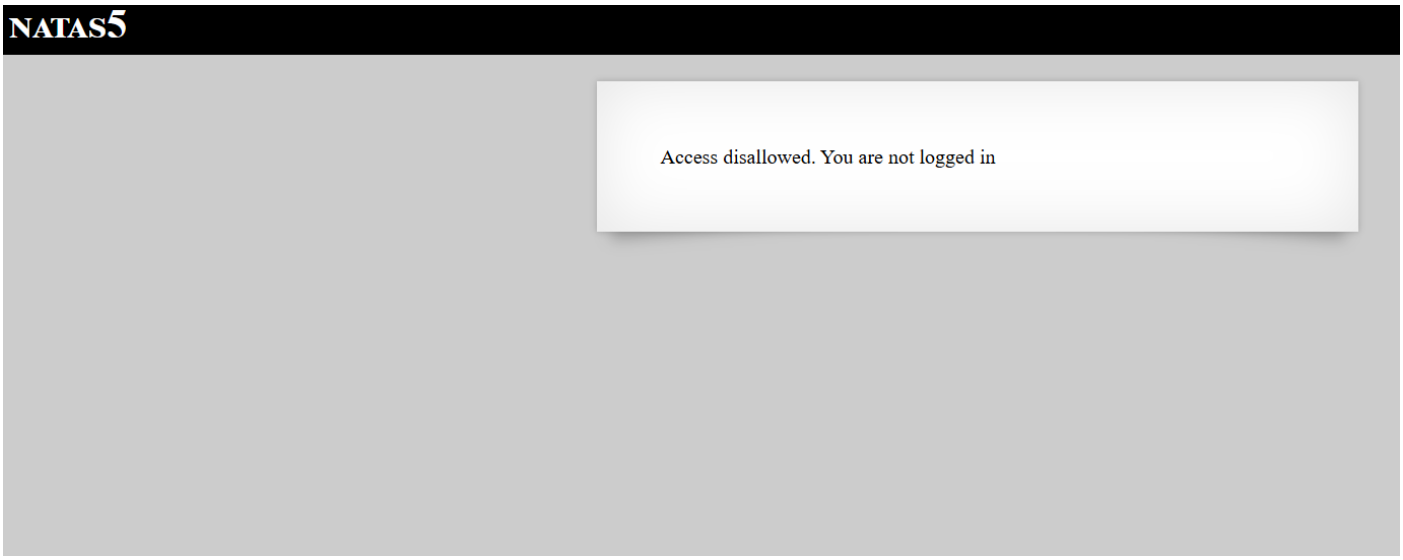


Burada referer kısmını bize verilen yetkili kişi nin url sini veriyoruz.



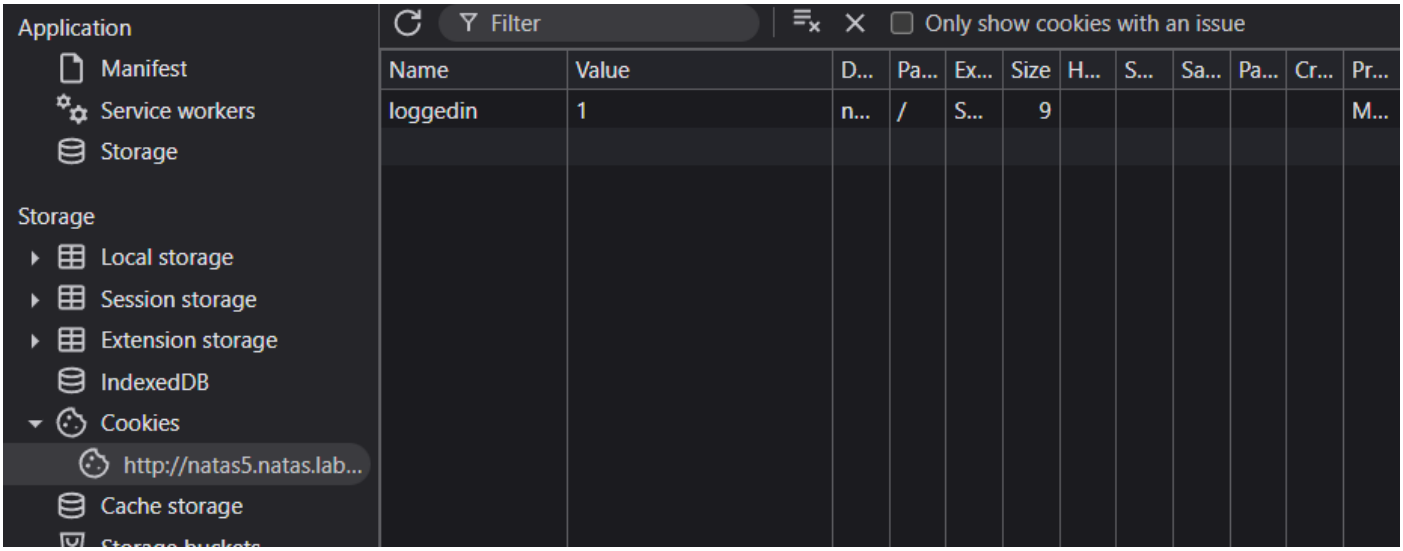
4→5

Bu bölüm coookie lerle alakalı bizim kim olduğumuzu kanıtlamamız lazım.

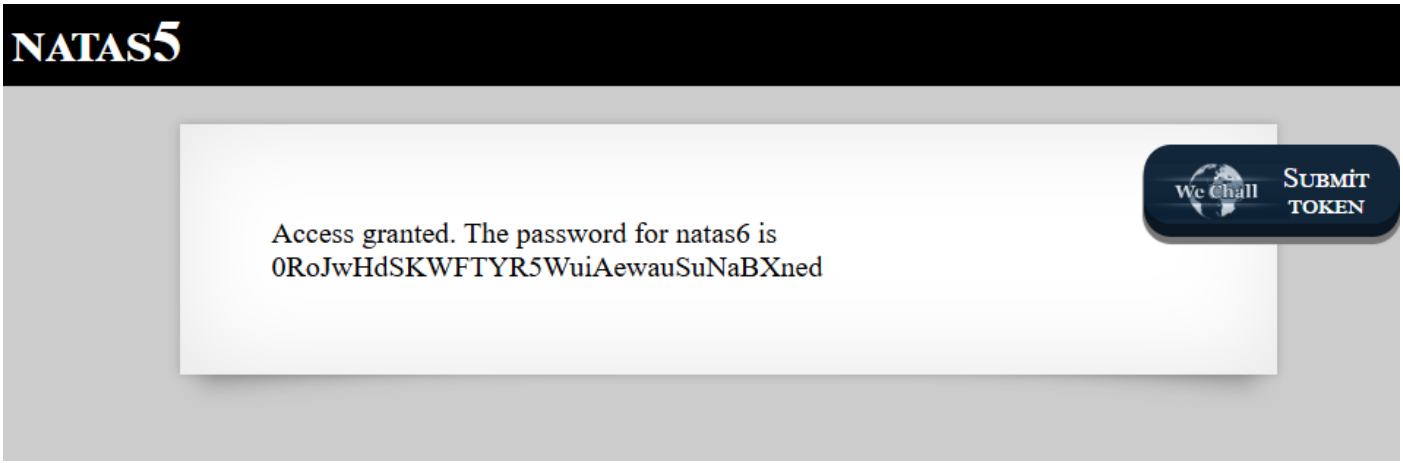


F12→aplication→cookie→ http://natas5.natas.labs.overthewire.org/ geliyoruz.

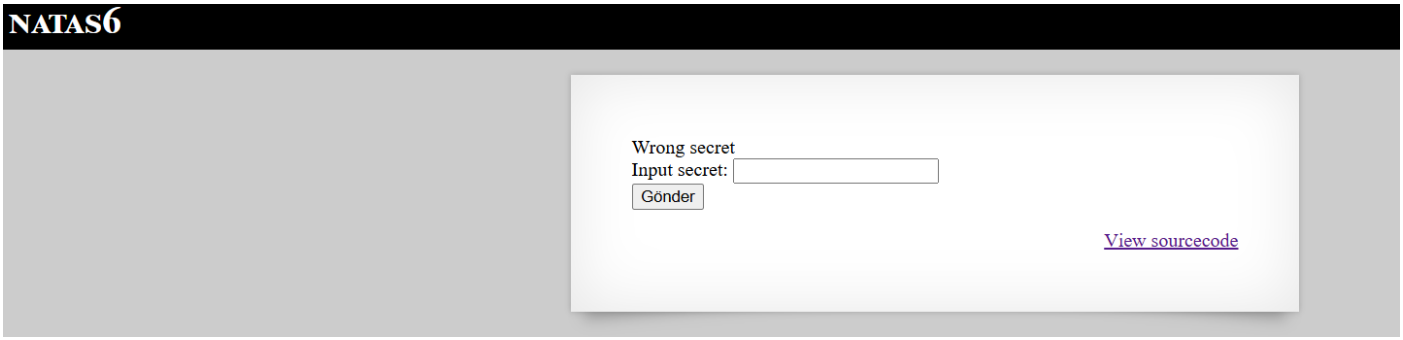
Buradaki value değerini 1 yapmamız lazım bu sayede içeri girebilicez.(0 olması bize izin vermediği anlamına geliyor)



Sayfayı yenileyince cevap ortaya çıktı.



5→6



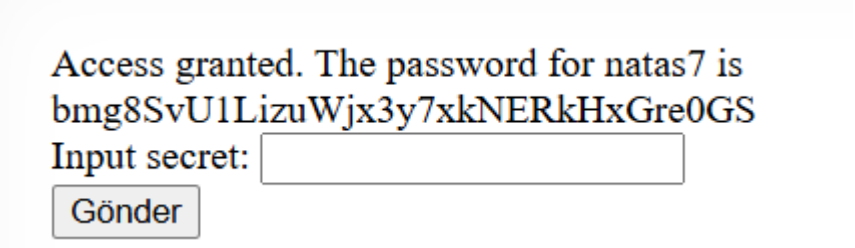
Buradan wiew sourcecode kısmına gidiyoruz.

```
include "includes/secret.inc";

    if(array_key_exists("submit", $_POST)) {
        if($secret == $_POST['secret']) {
        print "Access granted. The password for natas7 is <censored>";
    } else {
        print "Wrong secret";
    }
    }
?>
```

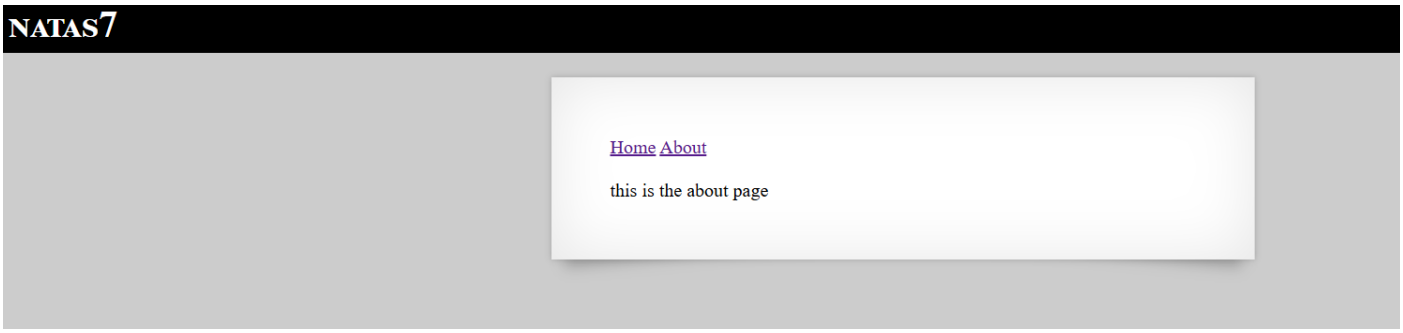
Bu kısım çok önemli çünkü kontrol mekanizması includes/secret.inc altında buraya url den ulaşabilirmiyiz diye bakıyoruz(url sonuna /includes/secret.inc yazıcaz)

```
<?
$secret = "FOEIUWGHFEEUHOFUOIU";
?>
```

Demekki ilk sayfaya bunu girersek sonuca ulaşırız.



6→7

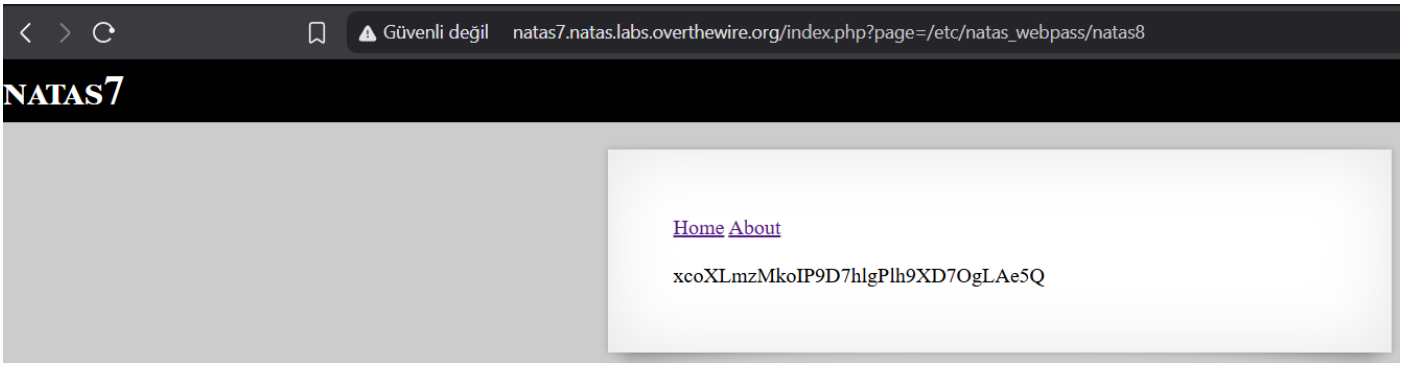


Sayfanın kaynağını görüntüle diyoruz.

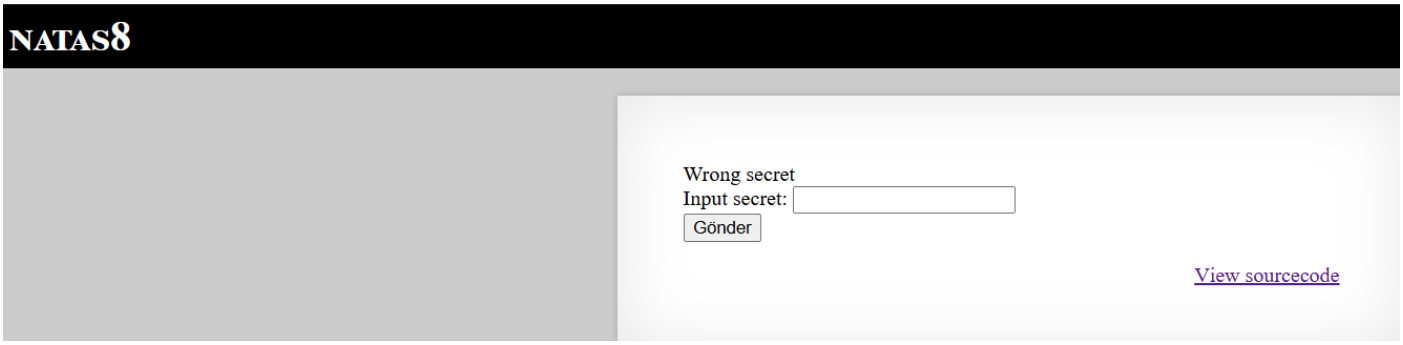
```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src=http://natas.labs.overthewire.org/js/wechall-data.js></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas7", "pass": "bmg8SvU1LizuWjx3y7xkNERkHxGre0GS" };</script></head>
<body>
<h1>natas7</h1>
<div id="content">

<a href="index.php?page=home">Home</a>
<a href="index.php?page=about">About</a>
<br>
<br>
this is the about page

<!-- hint: password for webuser natas8 is in /etc/natas_webpass/natas8 -->
</div>
</body>
</html>
```

Burada ipucu yazıyor /etc/natas/webpass/natas8 dizinine gidin diyor.

Burada path travels olabilir o yüzden page=/etc/natas/webpass/natas8 yazıyorum url ye.



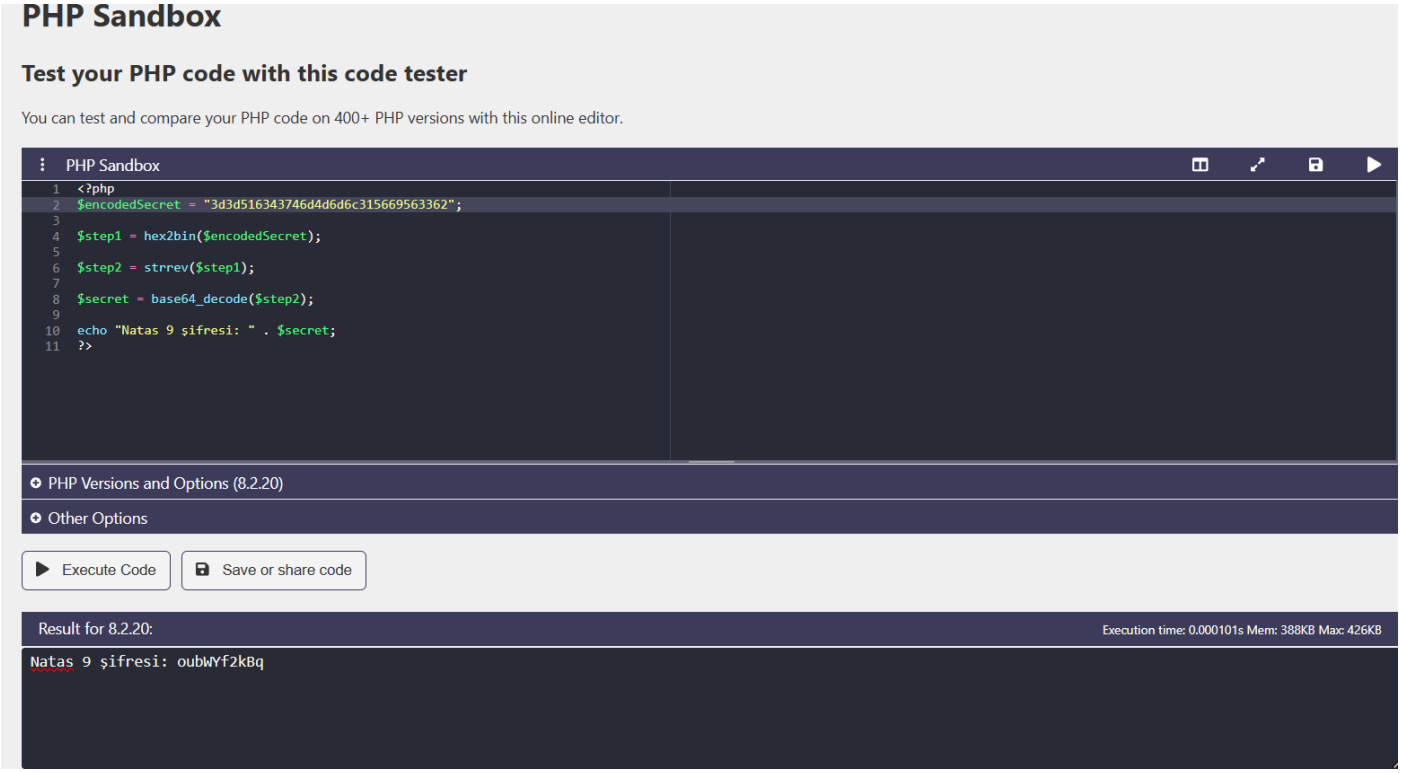
7→8



Yine kaynak kodlarını inceleyelim.

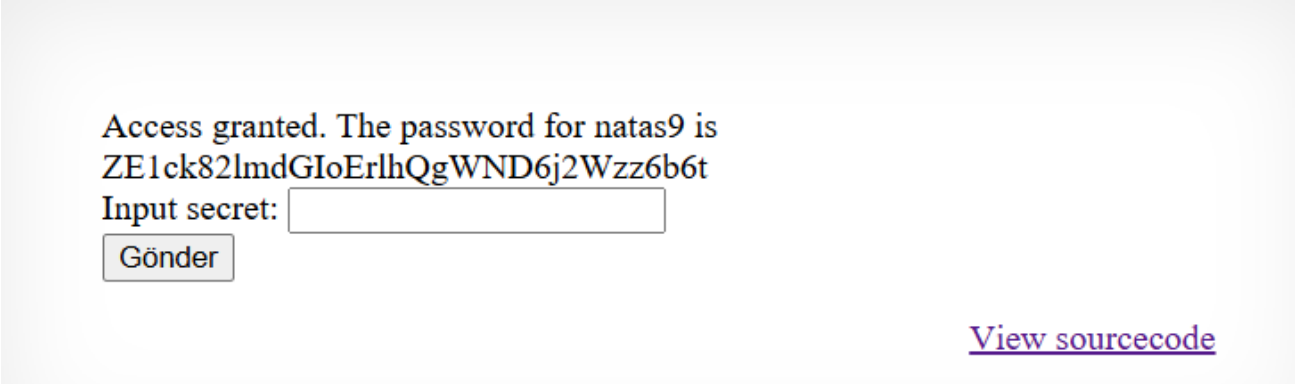
```php
$encodedSecret = "3d3d516343746d4d6d6c315669563362";

function encodeSecret($secret) {
    return bin2hex(strrev(base64_encode($secret)));
}

if(array_key_exists("submit", $_POST)) {
    if(encodeSecret($_POST['secret']) == $encodedSecret) {
    print "Access granted. The password for natas9 is <censored>";
    } else {
    print "Wrong secret";
    }
}
?>
```

Burada önce base64 sonra strrev sonrada bin2hex olarak çeviriyor. Biz ise şifreyi bulmak için bunun tam tersini yapmalıyız.

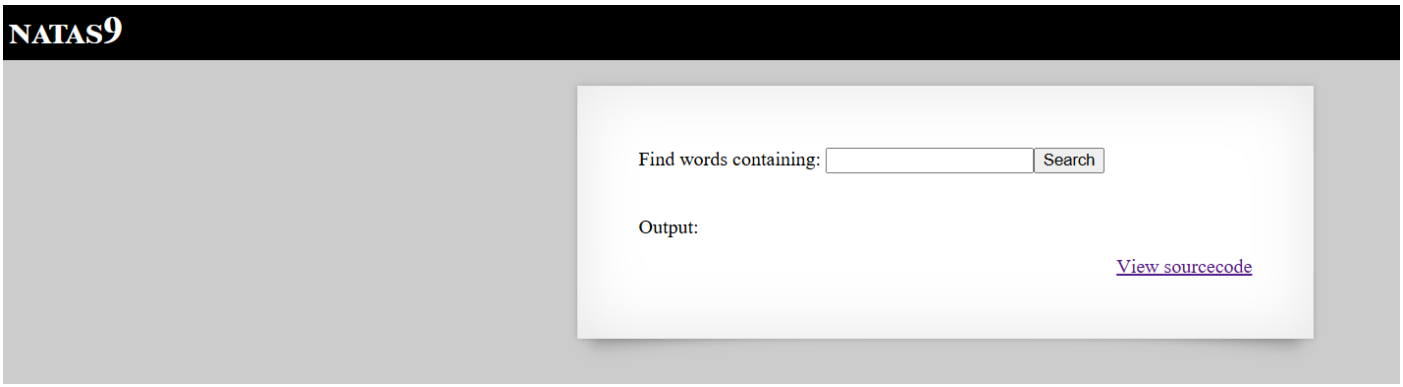


Bunun için yukardaki kodu yazmalıyız.

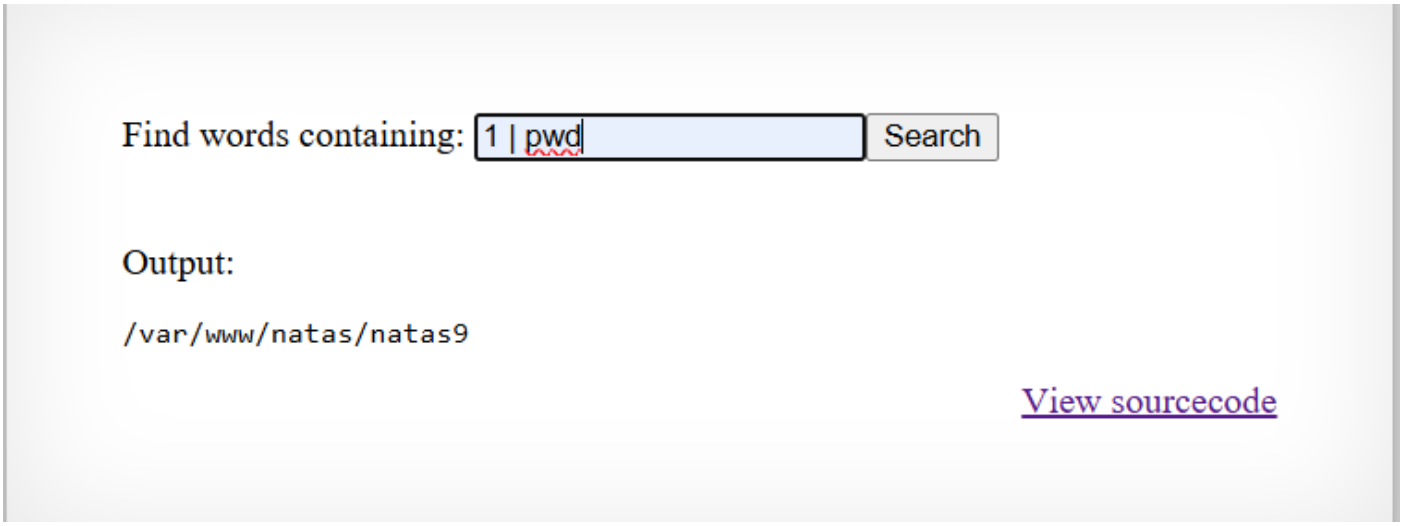
Çıkan sonucu ise bize verilen en baştaki kutucuğa yazıyoruz.



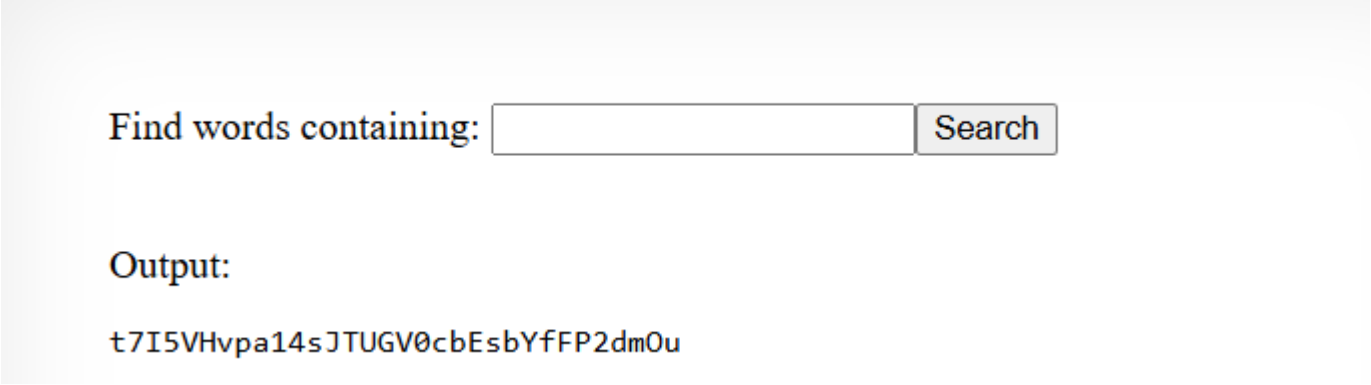
8→9



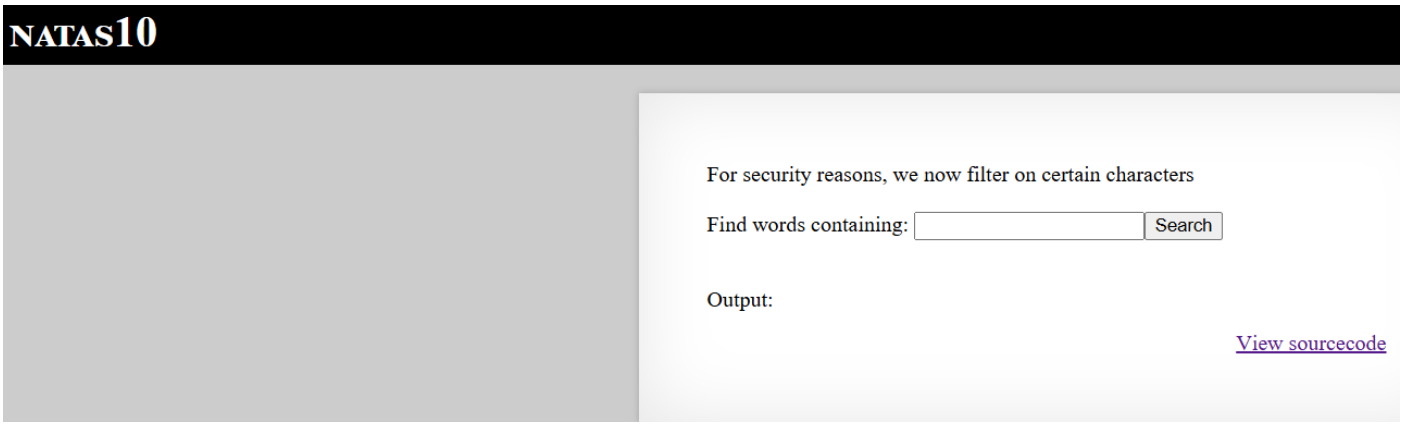
Buradaki find words containing kısmına (|) operatörünü kullanarak arka planda linux mu çalışıyor onu öğrenicem .



Arka planda linux çalışıyormuş bunu /etc/natas_webpass/natas10 konumuna gitmek için kullanıyorum.(1| cat /etc/natas_webpass/natas10)



9→10



Wiew sourscode kısmına bastığımızda özel karakterler yasaklanmış.

```
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    if(preg_match('/[;|&]/',$key)) {
        print "Input contains an illegal character!";
    } else {
        passthru("grep -i $key dictionary.txt");
    }
}
?>
```

Bu yüzden grep komutundaki açığı kullanmamız gerekiyor. .* /etc/natas_webpass/natas11 yazarak bu alanı aratabiliriz.

For security reasons, we now filter on certain characters

Find words containing: Search

Output:

```
.htaccess:AuthType Basic
.htaccess: AuthName "Authentication required"
.htaccess: AuthUserFile /var/www/natas/natas10/.htpasswd
.htaccess: require valid-user
.htpasswd:natas10:$apr1$QeE3dmBN$w9Tlpp1rLCe3nSKpwNObO.
/etc/natas_webpass/natas11:UJdqkK1pTu6VLt9UHWAgRZz6sVUZ3lEk
```

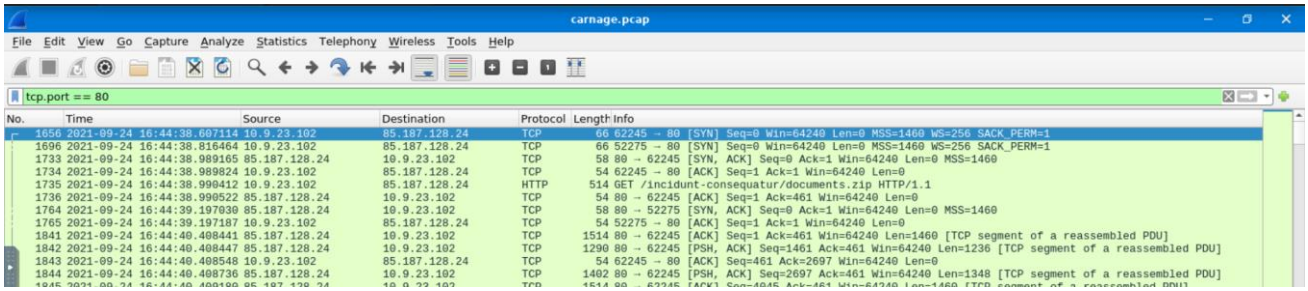
Natas11 şifresi en altta yazıyor.

Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi)

- **Senaryo: Satın alma departmanından Eric Fischer, bilinen bir kişiden gelen e-postadaki Word belgesini açıp yanlışlıkla "İçeriği Etkinleştir" butonuna tıkladı. SOC ekibi anında şüpheli dış bağlantı alarmları aldı ve ağ sensöründen alınan PCAP dosyasını size teslim etti.**
- **Hedef: TryHackMe: C2 Carnage**
- **Görev: Odaya girin, PCAP dosyasını Wireshark ile açın ve soruları yanıtlayarak zararlı yazılımın ağdaki izlerini sürün.**
- **Beklenti & Raporlama:**
  - **Zararlı bağlantıları, indirilen dosyaları ve komuta kontrol (C2) trafiğini tespit edin.**
  - **Soruları yanıtlarken hangi Wireshark filtresini (Örn: http.request.method == "POST") kullandığınızı teknik olarak açıklayın ve Wireshark ekran görüntüsünü ekleyin.**

1. **Kötü amaçlı IP'ye ilk HTTP bağlantısının tarihi ve saati neydi?**

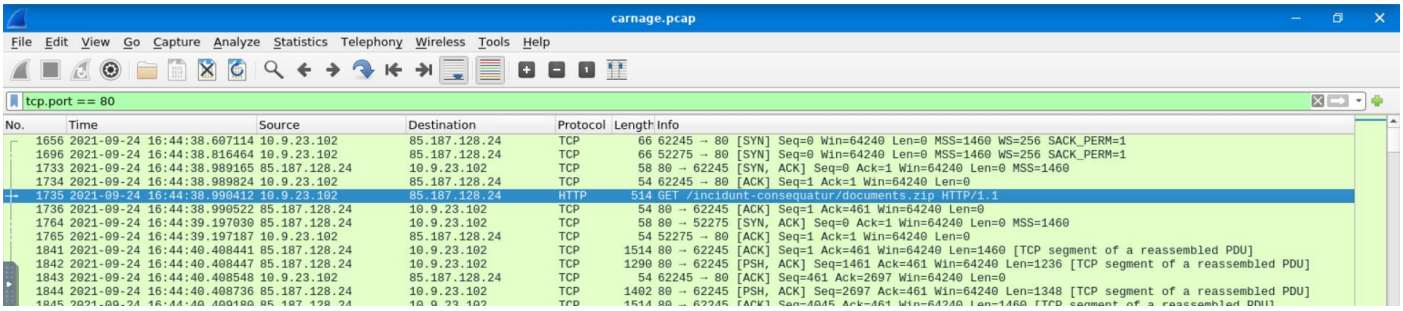
   Bize soruda http bağlantısı olduğunu söylemiş bu yüzden port 80 i aramalıyız.



   Ve ilk baağlantı sorulduğu için ilk syn paketini aldık.

   2021-09-24 16:44:38

2. **İndirilen zip dosyasının adı nedir?**



   Get metodu ile documents.zip indirilmiş.

3. Kötü amaçlı zip dosyasını barındıran alan adı neydi?

Wireshark · Follow TCP Stream (tcp.stream eq 73) · carnage.pcap

```
GET /incidunt-consequatur/documents.zip HTTP/1.1
Host: attirenepal.com
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.82 Safari/
537.36 Edg/93.0.961.52
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-
exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: en
```

Documents.zip in indirildiği pakete follow tcp stream dersek alan adı ortaya çıkıyor.

Host: Attirenepal.com

4. Dosyayı indirmeden, zip dosyasındaki dosyanın adı nedir?

```
00000210  20 6d 61 78 2d 61 67 65  3d 36 33 30 37 32 30 30   max-age =6307200
00000220  30 3b 20 69 6e 63 6c 75  64 65 53 75 62 44 6f 6d   0; inclu deSubDom
00000230  61 69 6e 73 0d 0a 78 2d  66 72 61 6d 65 2d 6f 70   ains..x- frame-op
00000240  74 69 6f 6e 73 3a 20 53  41 4d 45 4f 52 49 47 49   tions: S AMEORIGI
00000250  4e 0d 0a 78 2d 63 6f 6e  74 65 6e 74 2d 74 79 70   N..x-con tent-typ
00000260  65 2d 6f 70 74 69 6f 6e  73 3a 20 6e 6f 73 6e 69   e-option s: nosni
00000270  66 66 0d 0a 0d 0a                                  ff....
00000276  50 4b 03 04 14 00 00 00  08 00 e8 64 38 53 fc 61   PK...... ...d8S.a
00000286  ee f6 2f 05 03 00 00 d6  03 00 14 00 1c 00 63 68   ../..... ......ch
00000296  61 72 74 2d 31 35 33 30  30 37 36 35 39 31 2e 78   art-1530 076591.x
000002A6  6c 73 55 54 09 00 03 c3  9c 4d 61 ba 9d 4d 61 75   lsUT.... .Ma..Mau
000002B6  78 0b 00 01 04 00 00 00  00 04 00 00 00 00 ec 5b   x....... .......[
000002C6  77 5c 14 d7 da 3e bb 0c  5b e8 55 40 16 58 40 2c   w\...>.. [.U@.X@,
000002D6  80 02 4b 91 26 88 0d 89  05 35 d6 80 20 1a 10 13   ..K.&... .5.. ...
000002E6  63 01 34 8a 34 e3 67 bb  a8 88 58 88 60 48 34 84   c.4.4.g. ..X.`H4.
000002F6  a8 51 6c b1 23 18 15 82  6e 10 49 ec c6 02 5e b0   .Ql.#... n.I...^.
00000306  11 05 91 a2 e8 dc 73 66  59 98 99 9d 19 96 ef e6   ......sf Y.......
00000316  bb bf ef 8f bb 38 bb 73  de 79 cf f3 3c e7 7d df   .....8.s .y..<.}.
00000326  73 66 67 76 ac bc 6a f8  f0 bb c3 bd 1f 01 da 2b   sfgv..j. .......+
00000336  00 68 80 0f b8 18 08 48  36 0c 6e 4f 79 1d 0d 03   .h.....H 6.nOy...
00000346  00 8f e3 38 da 55 7e fe  13 1e ab 85 5b 1d dc 9e   ...8.U~. ....[...
00000356  c0 0d ff ef eb ff fd 4b  2c 82 89 14 68 82 4f 42   .......K ,...h.OB
00000366  7f 13 96 03 3e 10 88 00  78 04 3f 0f 61 e7 e1 3b   ....>... x.?.a..;
00000376  00 d5 70 0b 07 8b 00 34  4f fd 74 6e c2 67 73 63   ..p....4 O.tn.gsc
00000386  3f 97 fe 27 5e c3 08 0d  51 3c a4 a1 04 d6 d2 10   ?..'^... Q<......
00000396  5e 2f 58 91 fa 40 0f 68  03 1e 3c 86 01 4d 58 9b   ^/X..@.h ..<..MX.
000003A6  42 a8 2b 17 b6 0c 81 05  a1 d6 88 78 37 26 de 0b   B.+..... ...x7&..
000003B6  89 be 67 89 f7 21 f0 48  6b 6a 6b 6a d3 d4 68 37   ..g..!.H kjkj..h7
000003C6  6f 78 94 0f 31 a6 f3 87  12 7e 1b 89 77 3b e2 5d   ox..1... .~..w;.]
000003D6  8f 38 72 82 e8 73 87 b0  b8 01 6b 70 0f 7e 8a c0   .8r..s.. ..kp.~..
000003E6  66 54 f9 d0 24 e4 0d 07  51 60 3e 98 07 66 83 38   fT..$... Q`>..f.8
000003F6  f8 4e f7 90 ff 47 3c fe  1d 1d e2 6e 3d 02 ba f1   .N...G<. ...n=...
```

Bunun bie zip dosyası olduğunu biliyoruz o yüzden 50 4b 03 04(zip dosyasının magic byte) değerini documents.zip in indirldiği dosya içinde arıyoruz. Ve zipin içindeki belgenin adı chart-1530076591.xls olduğunu görüyoruz.

5. Zip dosyasının indirildiği kötü amaçlı IP'nin web sunucusunun adı nedir?

```
HTTP/1.1 200 OK
Connection: Keep-Alive
Keep-Alive: timeout=5, max=100
x-powered-by: PHP/7.2.34
set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/
content-description: File Transfer
content-type: application/octet-stream
content-disposition: attachment; filename=documents.zip
content-transfer-encoding: binary
expires: 0
cache-control: must-revalidate, post-check=0, pre-check=0
pragma: public
transfer-encoding: chunked
date: Fri, 24 Sep 2021 16:44:06 GMT
server: LiteSpeed
strict-transport-security: max-age=63072000; includeSubDomains
x-frame-options: SAMEORIGIN
x-content-type-options: nosniff
```

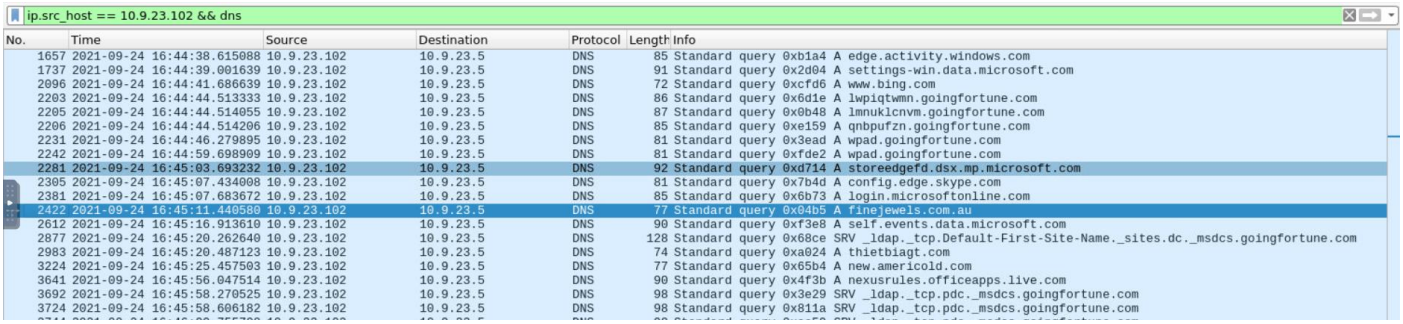
Paketin içinde server: LiteSpeed diye yazıyor.

6. **Önceki sorudaki web sunucusunun sürümü nedir?**

```
HTTP/1.1 200 OK
Connection: Keep-Alive
Keep-Alive: timeout=5, max=100
x-powered-by: PHP/7.2.34
set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/
```

Paket içerisinde x-poereed-by başlığı içinde PHP/7.2.34 yazıyor.

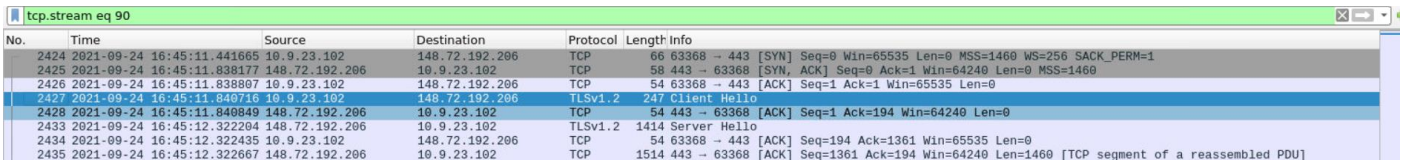
7. **Kötü amaçlı dosyalar kurban ana bilgisayarına birden fazla alan adından indirildi. Üçü neydi bu aktiviteye dahil olan alanlar?**



ip.src_host == 10.9.23.102 && dns sorgusunu arattım ve 3 tane adres çıktı

bunlar: finejewels.com.au, thietbiagt.com, new.americold.com

8. **Bir önceki sorudan SSL sertifikasını ilk alana hangi sertifika yetkilisi verdi?**



Bu şekilde aratıyoruz. Ve bizi içeri alan pakete follow tcp steam diyoruz.

Ve burada cevap çıkıyor. (Godaddy)

9. **Cobalt Strike sunucularının iki IP adresi nedir? IP'lerin Cobalt Strike C2 sunucuları olarak tanımlanıp tanımlanmadığını doğrulamak için VirusTotal'ı (Topluluk sekmesi) kullanın. (cevap formatı: IP adreslerini sıralı sırayla girin)**

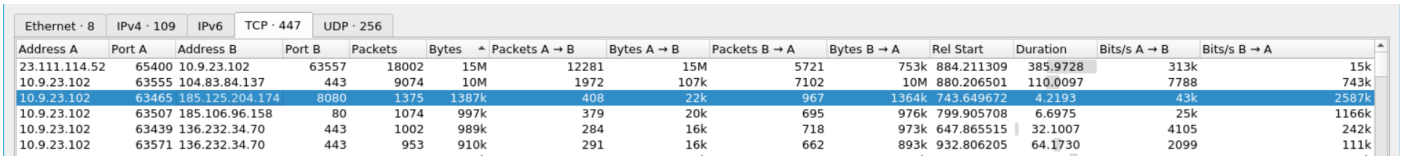
Öncelikle bu kısmıda yapmamız gerekenler sırayla:

Wiresahrkın üst sekmesinden Statistics kısmına geliyoruz.

Oradan Conversations kısmına tıklıyoruz.

Son olarak ise çıkan ekranda tcp ye tıklayıp bytes kısmını sıralıyoruz.

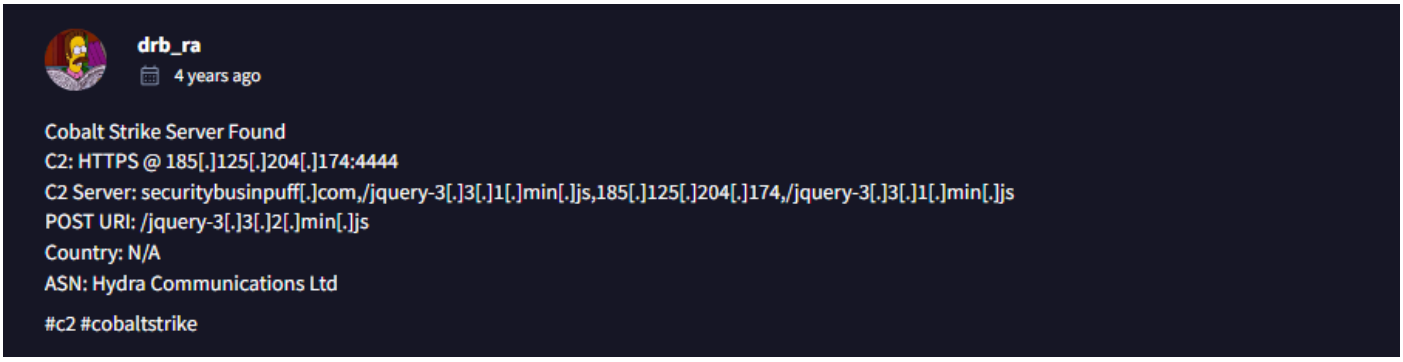
Bunu yapmamızın sebebi C2 sunucuları sürekli birbirlerine veri göndermesidir.



Ethernet · 8 | IPv4 · 109 | IPv6 | TCP · 447 | UDP · 256

Address A	Port A	Address B	Port B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
23.111.114.52	65400	10.9.23.102	63557	18002	15M	12281	15M	5721	753k	884.211309	385.9728	313k	15k
10.9.23.102	63555	104.83.84.137	443	9074	10M	1972	107k	7102	10M	880.206501	110.0097	7788	743k
10.9.23.102	63465	185.125.204.174	8080	1375	1387k	408	22k	967	1364k	743.649672	4.2193	43k	2587k
10.9.23.102	63507	185.106.96.158	80	1074	997k	379	20k	695	976k	799.905708	6.6975	25k	1166k
10.9.23.102	63439	136.232.34.70	443	1002	989k	284	16k	718	973k	647.865515	32.1007	4105	242k
10.9.23.102	63571	136.232.34.70	443	953	910k	291	16k	662	893k	932.806205	64.1730	2099	111k

Buradaki 2. Ve 3. Kısımlardaki ip adresleri en çok veri gönderenler bunları virüs totalden kontrol ediyoruz.



drb_ra
4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]125[.]204[.]174:4444
C2 Server: securitybusinpuff[.]com,/jquery-3[.]3[.]1[.]min[.]js,185[.]125[.]204[.]174,/jquery-3[.]3[.]1[.]min[.]js
POST URI: /jquery-3[.]3[.]2[.]min[.]js
Country: N/A
ASN: Hydra Communications Ltd

#c2 #cobaltstrike

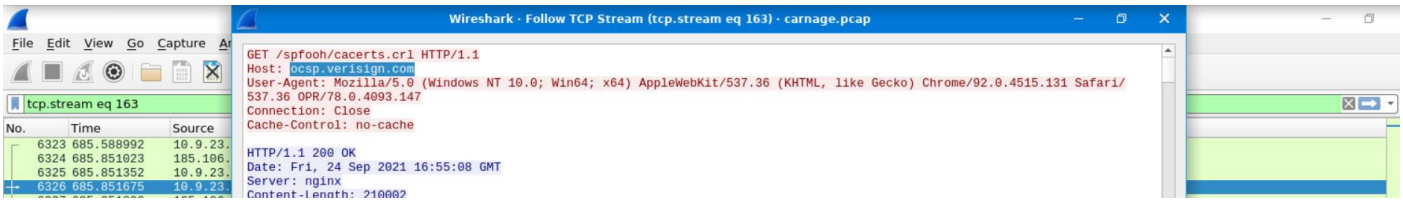
drb_ra
4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]106[.]96[.]158:8888
C2 Server: survmeter[.]live,/gscp[.]R/,185[.]106[.]96[.]158,/gscp[.]R/
POST URI: /supprq/sa/
Country: United States
ASN: DediPath
Host Header: ocsp[.]verisign[.]com

#c2 #cobaltstrike

C2 sunucuları olduğu ortaya çıkıyor.

10. Önceki sorudaki ilk Cobalt Strike IP adresinin Ana Bilgisayar başlığı nedir?



Bulduğumuz ip adresini aratarak (ip.src_host == 185.106.96.158) şeklinde aratıyoruz. Follow tcp stream diyince host ortaya çıkıyor. (ocsp.verisign.com)

11. **Cobalt Strike sunucusunun ilk IP adresinin alan adı nedir? VirusTotal'ı Cobalt Strike sunucusu olup olmadığını onaylamak için kullanabilirsiniz (Topluluk sekmesini kontrol edin).**

6323	685.588992	10.9.23.102	185.106.96.158	TCP	66 63447 → 80 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM=1
6324	685.851023	185.106.96.158	10.9.23.102	TCP	58 80 → 63447 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460

Buradaki 6324. Paket ilk c2 sunucusuna ait. Resolve ntework addres değerini açarsak eğer karşımıza şu çkıyor:

6324	685.851023	survmeter.live	DESKTOP-IOJC6RB.goi…	TCP
6325	685.851352	DESKTOP-IOJC6RB.goi…	survmeter.live	TCP
6326	685.851675	DESKTOP-IOJC6RB.goi…	survmeter.live	HTTP
6327	685.851803	survmeter.live	DESKTOP-IOJC6RB.goi…	TCP
6328	686.159186	survmeter.live	DESKTOP-IOJC6RB.goi…	TCP

Cevap: survmeter.live

12. **İkinci Cobalt Strike sunucusu IP'nin alan adı nedir? VirusTotal'ı Cobalt Strike sunucusu olup olmadığını onaylamak için kullanabilirsiniz (Topluluk sekmesini kontrol edin).**

ip.addr == 185.125.204.174

No.	Time	Source	Destination	Protocol	Length	Info
5134	646.573594	securitybusinpuff.com	DESKTOP-IOJC6RB.goi…	TCP	275	8080 → 63438
5135	646.573681	DESKTOP-IOJC6RB.goingfortune…	securitybusinpuff.c…	TCP	54	63438 → 8080
5136	646.573928	DESKTOP-IOJC6RB.goingfortune…	securitybusinpuff.c…	TCP	54	63438 → 8080
5137	646.574026	securitybusinpuff.com	DESKTOP-IOJC6RB.goi…	TCP	54	8080 → 63438
6251	682.303966	DESKTOP-IOJC6RB.goingfortune…	securitybusinpuff.c…	TCP	66	63445 → 8080
6266	682.482017	securitybusinpuff.com	DESKTOP-IOJC6RB.goi…	TCP	58	8080 → 63445
6267	682.482504	DESKTOP-IOJC6RB.goingfortune…	securitybusinpuff.c…	TCP	54	63445 → 8080

Yukardaki souyla aynı mantıkla bunun cevabıda: securitybusinpuff.com

13. **Enfeksiyon sonrası trafiğin alan adı nedir?**

http

No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	DESKTOP-IOJC6RB.goingfortune.com	attirenepal.com	HTTP	514	GET /incidunt-consequatur/documents.zip HTTP/1.1
2173	59.234150	attirenepal.com	DESKTOP-IOJC6RB.goi…	HTTP	580	HTTP/1.1 200 OK
3822	153.653113	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= H
3851	154.401688	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	178.767210	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	285	POST /zLIisQRWZI9/ASk5Kx0SPR8lJjE5eTg9GkN6fGFyZHl/YXp6eQ
3912	179.543303	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	203.829455	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	285	POST /zLIisQRWZI9/fXMKNg0nKzN/DA15DggBI0N6fGFyZHl/YXp6eQ
4000	204.546015	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
4006	228.842458	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	273	POST /zLIisQRWZI9/eDkkAA0bInx9Rnp6ZXVheXllfX95 HTTP/1.1
4010	229.568579	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
4017	254.037243	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	293	POST /zLIisQRWZI9/LjI+JSoqJQ41BiwyAhR7KngvHgopKBhFfntkcm
4021	254.776306	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)

Görüldüğü üzere dosya indirildikten sonra trfik maldivehost.net üzerinden devam etmiş.

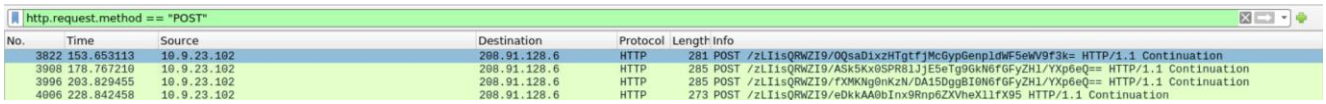
14. **Kurban ana bilgisayarın enfeksiyon sonrası trafiğe dahil olan kötü amaçlı alana gönderdiği ilk on bir karakter nedir?**

http

No.	Time	Source	Destination	Protocol	Length	Info
1735	56.248525	DESKTOP-IOJC6RB.goingfortune.com	attirenepal.com	HTTP	514	GET /incidunt-consequatur/documents.zip HTTP/1.1
2173	59.234150	attirenepal.com	DESKTOP-IOJC6RB.goi…	HTTP	580	HTTP/1.1 200 OK
3822	153.653113	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= H
3851	154.401688	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	178.767210	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	285	POST /zLIisQRWZI9/ASk5Kx0SPR8lJjE5eTg9GkN6fGFyZHl/YXp6eQ
3912	179.543303	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	203.829455	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	285	POST /zLIisQRWZI9/fXMKNg0nKzN/DA15DggBI0N6fGFyZHl/YXp6eQ
4000	204.546015	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
4006	228.842458	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	273	POST /zLIisQRWZI9/eDkkAA0bInx9Rnp6ZXVheXllfX95 HTTP/1.1
4010	229.568579	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)
4017	254.037243	DESKTOP-IOJC6RB.goingfortune.com	maldivehost.net	HTTP	293	POST /zLIisQRWZI9/LjI+JSoqJQ41BiwyAhR7KngvHgopKBhFfntkcm
4021	254.776306	maldivehost.net	DESKTOP-IOJC6RB.goi…	HTTP	634	HTTP/1.1 200 OK (text/html)

Dosya indirildekten sonra ilk Post isteği zLIisQRWZI9 şeklindedir.

15. C2 sunucusuna gönderilen ilk paketin uzunluğu neydi?



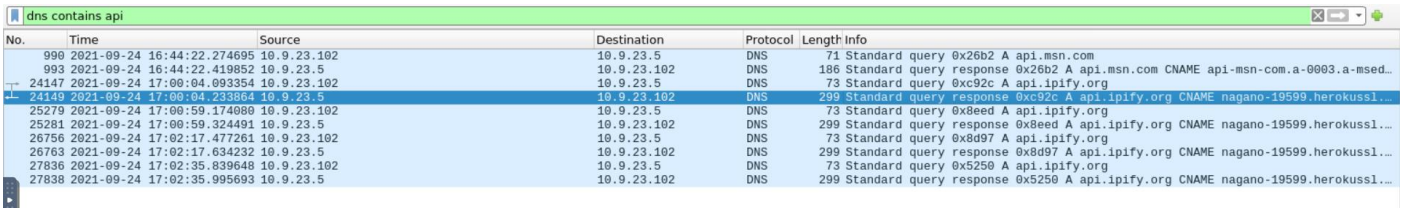
Burada post isteklerini filtreleyerek iletişim için gönderilen ilk paketin uzunluğunun 281 olduğunu buluruz.

16. Önceki sorudaki kötü amaçlı etki alanı için Sunucu başlığı neydi?

Yukardaki baktığımız pakete follow tcp stream diiyince cevap karşımıza çıkıyor.

Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

17. Kötü amaçlı yazılım, kurbanın makinesinin IP adresini kontrol etmek için bir API kullandı. Tarih ve saat neydi DNS IP kontrol alanı için sorgu oluştu mu? (cevap biçimi: yyyy-mm-dd hh:mm:ss UTC)

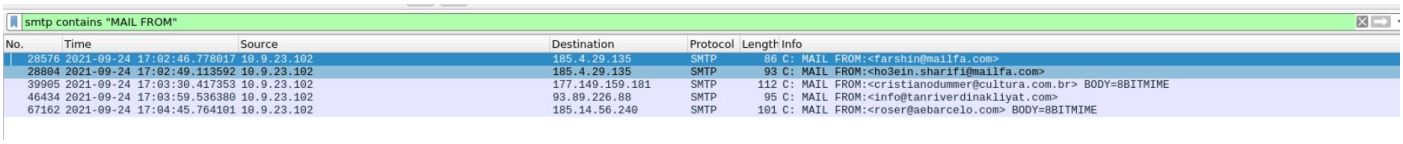


Burada dns contains api araması yapıyoruz yani dns içinde api kelimesini arıyoruz. Api genellikle sorguyu ipify.org'a atar o yüzden cevap: 2021-09-24 17:00:04

18. Önceki sorudaki DNS sorgusundaki etki alanı neydi?

Yukarıdaki fotoğrafta zaten etki alanını söylemiş olduk: api.ipify.org

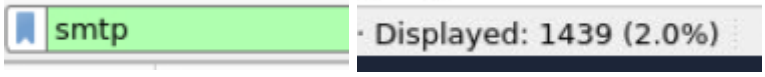
19. Görünüşe göre bazı kötü amaçlı spam (malspam) etkinlikleri yapılıyordu. Trafikte gözlenen ilk MAIL FROM adresi neydi?



smtp contains "MAIL FROM" Bu şekilde smtp istekleri içinde mail from kelimesini aramış olduk.

farshin@mailfa.com

20. SMTP için kaç paket gözlemlendi trafik?



Smtp araması yaptığımızda 1439 paket içerdiğini görüyoruz.

BÖLÜM C: Av Mevsimi (Saha Adımları)

Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)

Nişanlar › Chime Yönetilen Böcek Ödül Nişan

Böcek Ödülü

Chime Yönetilen Böcek Ödül Nişan

Finansal ilerlemelerinin kilidini açmak için sıradan insanları birleştiriyoruz!

Finans • Güvenli liman

Kapsam derecelendirmesi	Test süresi	Durum
4 dışarı 4	**Devam ediyor** Başladı 06 Mayıs 2025	Devam ediyor 06 Mayıs 2025 18:00:00 GMT+0

Zafiyet arayacağım site olarak chime yi seçtim.

```
└─$ subfinder -d chime.com | httpx-toolkit -status-code

   _    __  __       _ __
  / /_  / /_/ /____ | |/ /
 / _ \ / __/ / __ \|   /
/ / / / /_/ /_/ /_/ /   |
/_/ /_/\__/\__/ .___/_/|_|
             /_/            v1.1.5

                projectdiscovery.io

Use with caution. You are responsible for your actions.
Developers assume no liability and are not responsible for any misuse or damage.

          __   ____          __
  ______  _/ /_  / __(_)___  ___/ /_  ____
 / __/ / / / __ \/ /_/ / __ \/ __  / __/
(__  ) /_/ / /_/ / __/ / / / / /_/ /  __/ /
/____/\__,_/_.___/_/ /_/_/ /_/\__,_/\___/_/

                projectdiscovery.io

[INF] Current subfinder version v2.12.0 (latest)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for chime.com
[INF] Found 262 subdomains for chime.com in 21 seconds 126 milliseconds
https://16002407.account.chime.com [404]
https://16002407.notify.chime.com [404]
http://bounce.chime.com [403]
https://arkose-client.chime.com [404]
https://attachments.chime.com [301]
https://careers.chime.com [302]
https://app.chime.com [307]
https://employers.wp-qa.chime.com [403]
https://enterprise.chime.com [403]
https://email.gh-mail.ext.chime.com [404]
https://datadog-forwarder-nonprod.chime.com [308]
https://email.gh-mail.chime.com [404]
https://autobots.chime.com [403]
https://app-qa.chime.com [307]
https://email.mg.chime.com [404]
https://autobots-qa.chime.com [403]
https://email.teamable.chime.com [404]
https://enterpriseregistration.chime.com [404]
https://enterpriseenrollment.chime.com [302]
https://email.news.chime.com [404]
https://datadog-forwarder.chime.com [308]
https://developer.chime.com [200]
https://autobots-dev1.chime.com [403]
https://email.talent.chime.com [404]
```

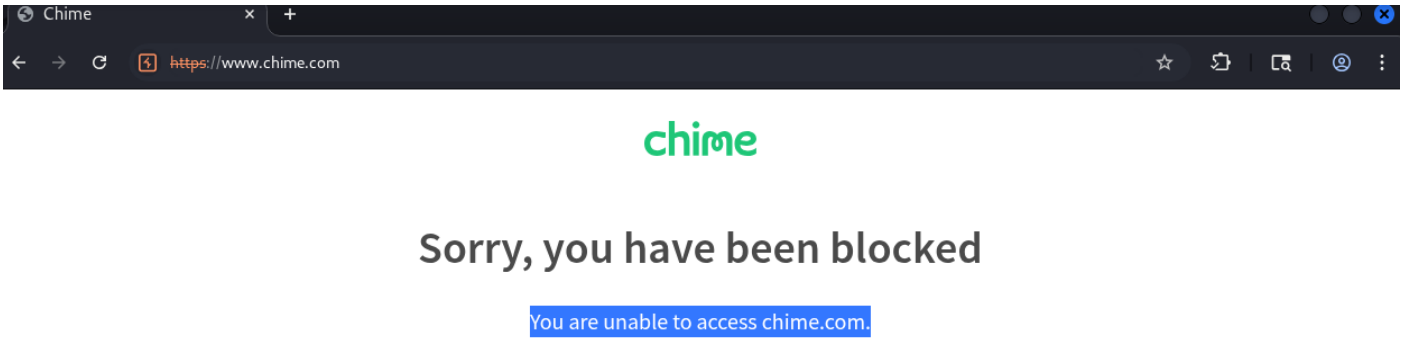
```
https://error-pages.chime.com [403]
https://help.chime.com [301]
https://handbooks.chime.com [200]
https://email.ethnio.chime.com [404]
https://flashpaper-dev1.chime.com [200]
https://interchange.chime.com [302]
https://flashpaper-qa.chime.com [200]
https://employers.wp-dev3.chime.com [400]
https://employers.wp-dev1.chime.com [400]
https://flashpaper.chime.com [200]
https://employers.wp-dev2.chime.com [400]
https://employers.wp-dev5.chime.com [400]
https://employers.wp-dev4.chime.com [400]
https://links.account.chime.com [404]
https://links.notify.chime.com [404]
https://inspector.chime.com [403]
https://inspector-qa.chime.com [403]
https://inspector-dev1.chime.com [403]
https://locations-qa.chime.com [403]
https://m.chime.com [404]
https://mobile-state.chime.com [403]
https://nd.chime.com [403]
https://locations.chime.com [403]
https://member-qa.chime.com [301]
https://penny-dev1.chime.com [403]
https://monocle-qa.chime.com [403]
https://member.chime.com [301]
https://monocle-dev1.chime.com [403]
https://member-dev1.chime.com [301]
https://monocle.chime.com [499]
https://penny-qa.chime.com [403]
https://s.chime.com [404]
https://public-assets.chime.com [403]
https://public-assets-qa.chime.com [403]
https://public-assets-dev1.chime.com [403]
https://penny.chime.com [403]
https://status.chime.com [200]
https://wp-dev1.chime.com [403]
https://static-attachments.chime.com [404]
https://wp-dev2.chime.com [403]
https://research.chime.com [302]
https://wp-dev5.chime.com [403]
https://wp-dev4.chime.com [403]
https://workplace-qa.chime.com [301]
https://www.chime.com [403]
https://wp-qa.chime.com [403]
https://wp-dev3.chime.com [403]
https://workplace.chime.com [301]
https://tags.chime.com [403]
https://vpn.chime.com [200]
```

```
[19:40:34] 403 -  427KB - /_logs/error_log
[19:40:35] 403 -  427KB - /access_log
[19:40:36] 403 -  427KB - /access.log
[19:40:41] 403 -  427KB - /admin/error.log
[19:40:41] 403 -  427KB - /admin.old
[19:40:42] 403 -  427KB - /admin/logs/error.log
[19:40:42] 403 -  427KB - /admin/_logs/access_log
[19:40:42] 403 -  427KB - /admin/access.log
[19:40:42] 403 -  427KB - /admin/error_log
[19:40:42] 403 -  427KB - /admin/log/error.log
[19:40:42] 403 -  427KB - /admin/_logs/error.log
[19:40:42] 403 -  427KB - /admin/_logs/error_log
[19:40:43] 403 -  427KB - /admin/_logs/access.log
[19:40:43] 403 -  427KB - /admin/logs/access_log
[19:40:43] 403 -  427KB - /admin/logs/access.log
[19:40:43] 403 -  427KB - /admin/logs/error_log
```

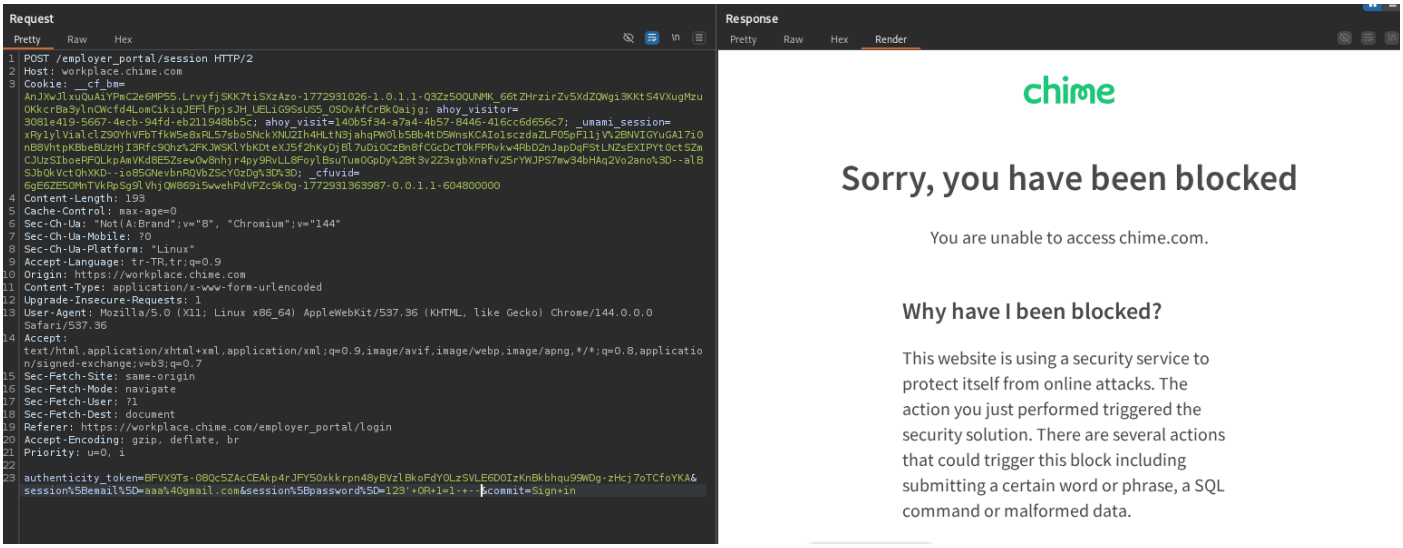
Burada 403 durum kodları ilgimi çekti ve birine dirsearch attım(https://employers.wp-qa.chime.com) ve sol taraftaki admin le alakalı yerler ortaya çıktı.

https://www.chime.com/

Sadece bu kısım vardı ve buralara ' OR 1=1 – ve <script>alert(1)</script> denememe rağmen bir şey olmadı. Burp suit kullandım ama engellemişler burp suit ile girilmiyordu.



https://workplace.chime.com/employer_portal/login



Belki burada vardır diye '+OR+1=1-+-- denedim ama yine engellenmiş.

<script>alert(1)</script> sonrasında bunuda denedim ama yine aynı sayfaya attı. Engellenmiş.

İçeriye giremediğim için bir IDOR rastlamadım ve Fotoğraf yükleme yeride yoktu.

<object data="data:text/html,<script>alert(5)</script>">

<body onload=alert()>

Daha sonrasında bunlarıda denedim ama hep aynı hatayı aldım her seferinde Cloudflare WAF'a takılıyordu.

BÖLÜM D: Mühendislik Vizyonu (Reflection)

1. Etki Analizi (Impact & CVSS Mantığı): *Senaryo:* Hedef şirkette iki farklı XSS zafiyeti buldunuz. Birincisi, şirketin ana sayfasında kimsenin uğramadığı bir "Hakkımızda" sayfasındaki arama çubuğunda (Reflected XSS). İkincisi ise yöneticilerin girdiği iç ağdaki (Admin Panel) yorumlar bölümünde (Stored XSS).

- **Soru:** Sadece "İkisi de XSS" diyerek geçemeyiz. Bu iki zafiyetin CVSS skorları ve şirkete vereceği zarar (Impact) neden birbirinden tamamen farklıdır? VDP yetkilisine bu iki açığın risk seviyesini nasıl kıyaslayarak açıklarsınız?

→Buradaki reflected xss in zararlı olabilmesi için o anda kullanıcının önüne düşen linke tıklaması gerekir birde kimsenin uğramadığı bir yer olunca risk seviyesi düşük olarak nitelendirebiliriz. Ama admin panelinde bir stored xss olması kullanıcının oraya girmesiyle çalışır bir linke tıklamasına gerek yoktur bu yüzden risk seviyesi en yüksek olan kritik seviyesindedir.

2. Çözüm Üretmek (Mitigation): *Senaryo:* Yazılım ekibi size geri dönüş yaptı: "*Bize SQL Injection açığını bulduğun için teşekkür ederiz. Arama kutusuna girilen ' (tek tırnak) karakterini yasaklayarak açığı kapattık.*"

- **Soru:** Bir mühendis olarak, sadece tırnak işaretini (veya belirli kelimeleri) yasaklamanın (Blacklisting) neden kalıcı ve güvenli bir çözüm olmadığını nasıl açıklarsınız? SQLi zafiyetini **kökten** çözmek için yazılımcılara hangi mimari yaklaşımı (Örn: Prepared Statements / Parametrik Sorgular) önermeniz gerekir? Mantığını açıklayın.

→Burada sadece ‘işaretinin yasaklanması sayfayı tamamen korumaz çünkü ‘ işareti ASCII, UrL encode(%27), Unicode vb. formatlarda yazarak geçebilir. Tamamen önlemek için ise Prepared Statements yöntemi kullanılmalı.

Prepared Statements: Girilen metnin bir kod olarak değilde tamamen bir string olan veri tipi olarak kaydedilmesidir. Zaralı kod yazılsa bile onu normal bir string miş gibi algılayıp kaydedicek.